The OWASP Top 10 for LLM applications



AI security · University · Lesson 2

In this lesson you will

- Name the ten OWASP risks for LLM apps, with an example of each.
- Treat model output as untrusted: escape it before it is used.
- Keep secrets and access rules out of prompts.

Remember

- In: LLM01 injection, LLM04 poisoning, LLM08 embeddings. Out: LLM02 disclosure, LLM07 prompt leakage, LLM05 output handling, LLM09 misinformation. System: LLM03 supply chain, LLM06 agency, LLM10 consumption.
- Model output is untrusted input.
- Assume the system prompt will be read.

Ten-risk review

1. Sort (5 min): Ten risk cards into in, out and the system.
2. Review (8 min): Could each one happen in your app?
3. Fix (5 min): A control for your top three.
4. Test (2 min): How would you prove one control works?

Review your own app or a made-up design. Never test a live app without written permission.

Let’s discuss

1. Why is the model's reply untrusted, even though your app asked for it?
2. Which risk is easiest to fix by design?
3. Why doesn't “never reveal this” protect a secret?

Check yourself

- Write one risk from the ten that applies to an app you use, and its control.